

# Lo que se necesita vs. lo que hace hoy

Auditoría de funciones, permisos, sistemas y subida de archivos — contrastando los requerimientos documentados contra el código real y verificando el estado en local y en producción. Incluye la reconciliación con las auditorías previas, varias de cuyas brechas ya están cerradas.

Fecha · 2026-07-20

Alcance · shell vivo /demo + BFF + BD

Ejes · funciones · permisos · uploads · sistemas

Verificación · código + runtime local + prod

VEREDICTO

## Resumen ejecutivo

**El núcleo de negocio está implementado y es persistente.** Toda la cadena comercial → producción → operación → fiscal → cobranza corre de verdad contra Postgres en el shell vivo: propuestas por método del divisor con liga pública y aprobación por sitio, campañas por tipo de medio con guards server-side, creativos, imprenta, OT con evidencia, finanzas con abonos y candado. Las brechas para "producción real" son **transversales y acotadas**, no del flujo.

~90%

FUNCIONALIDAD DE NEGOCIO

~55%

LISTO PARA PRODUCCIÓN

3

BLOQUEANTES EXTERNOS

8

HALLAZGOS DE PERMISOS

1/7

UPLOADS CON VALIDACIÓN

**Hallazgo transversal:** las auditorías previas del repo van **por detrás del código**. Varias brechas que aún listan como pendientes ya están cerradas (bitácora inmutable, guard OOH→/creativo, propuesta→campana, calendario de rentas, renovar/cancelar contrato, adjuntos de pago, publicación real en DOOHmain). Este documento refleja el estado **verificado a hoy**.

EL COMPARATIVO · POR MÓDULO

## Necesita vs. hace, módulo por módulo

● Hace lo requerido   ● Parcial / con brecha   ● Falta o bloqueante

| MÓDULO                 | QUÉ SE NECESITA                                                                                                             | QUÉ HACE HOY                                                                                                 | BRECHA PRINCIPAL                                                                                                                   | ESTADO       |
|------------------------|-----------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------|--------------|
| Inventario             | CRUD de pantallas (fija/digital), specs, precios, imágenes, importación Excel, disponibilidad por catorcena.                | CRUD completo, importación Excel real (SheetJS), disponibilidad y anti-sobreventa por tipo de medio.         | Imágenes en base64; Computer Vision es solo imagen de muestra.                                                                     | ● OK         |
| Arrendadores y rentas  | Arrendador→predio→contrato, calendario de pagos, renovar/cancelar, adjuntos, P&L de margen.                                 | Todo implementado: calendario auto, renovar, cancelar, adjuntos de pago, margen por pantalla.                | Alertas de vencimiento solo si hay quien abra la app (sin correo).                                                                 | ● OK         |
| Clientes / agencias    | CRUD fiscal, comisión por agencia, bloqueo si la negociación no está validada, liquidar comisiones.                         | CRUD fiscal, comisión y negociación validada como bloqueante.                                                | <b>Liquidación/pago de comisiones a agencias: no existe</b> (solo configura el %).                                                 | ● Parcial    |
| Propuestas             | Método del divisor, aprobación por sitio, liga pública, aceptación del cliente, versionado, generar campaña, PDF.           | Todo, con liga por token no-enumerable, snapshot inmutable y <b>generar campaña</b> funcional (probado E2E). | "Generar PDF" de la propuesta es placeholder.                                                                                      | ● OK         |
| Campañas               | Pipeline por tipo, guards (DOOH→Imprenta, OOH→Creativo), colisión de fechas, TTL de reservas, snapshot.                     | Pipeline derivado de 12 etapas, ambos guards presentes, colisión 409, TTL 7d, snapshot inmutable.            | Ninguna material (TTL depende de tráfico, ver Sistemas).                                                                           | ● OK         |
| Creativos              | Alta imagen/HTML, aprobar/rechazar, asignar a spots.                                                                        | Todo + guard OOH y retiro/reemplazo con sincronía a DOOHmain.                                                | Creativos HTML no viajan bien a DOOHmain (se suben "a riesgo").                                                                    | ● OK         |
| Imprenta               | Orden solo OOH, prueba de color, avance de 5 etapas.                                                                        | Todo implementado, con guard DOOH→Imprenta (409).                                                            | —                                                                                                                                  | ● OK         |
| Operaciones / OT       | OT con checklist/fecha, cierre con foto+geo, vista móvil, alerta de OT vencida.                                             | Todo, con vista móvil dedicada y evidencia que enciende el candado.                                          | No hay entidad "cuadrilla" (asigna a usuario); alerta on-request; evidencia en base64.                                             | ● OK         |
| Finanzas               | Candado (OC+fotos+reporte), factura con IVA, plazos 60/90/120, cobranza con abonos, recordatorios, <b>timbrado fiscal</b> . | Candado server-side, factura con desglose, cobranza con abonos y semáforo.                                   | <b>Timbrado SIMULADO (folio UUID) — sin PAC/CFDI no se factura legalmente.</b>                                                     | ● Bloqueante |
| Network                | Catálogo de red, CMS por pantalla, red compartida entre CRMs con costo oculto, anti-duplicados.                             | Catálogo con conteo por CMS y toggle "En Network".                                                           | Comercialización cross-network real (compra-venta entre operadores) no existe.                                                     | ● Parcial    |
| DOOHmain / integración | Publicar campaña como sublista, proof-of-play real, conector por tenant.                                                    | Publicación real vía SDK Python <b>detrás de flag</b> (el código superó al diseño).                          | Proof-of-play se guarda crudo y no se interpreta (la API aún devuelve <code>[]</code> ); mapeo de pantallas por env, no auto-sync. | ● Parcial    |
| Admin / permisos       | Usuarios, RBAC 6 roles×módulo×acción, auth robusta, aislamiento multi-tenant.                                               | RBAC en BD, bcrypt cost 10, desbloqueo server-side, tokens no-enumerables, RLS fail-closed en 7 tablas.      | RLS parcial + IDOR en usuarios; GET sin gate por módulo; ver sección Permisos.                                                     | ● Endurecer  |
|                        |                                                                                                                             |                                                                                                              |                                                                                                                                    |              |

| MÓDULO                      | QUÉ SE NECESITA                                                                  | QUÉ HACE HOY                                                                                    | BRECHA PRINCIPAL                                                                                                  | ESTADO               |
|-----------------------------|----------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------|----------------------|
| Reportes /<br>proof-of-play | Reporte contratado vs entregado, testigos, KPIs, funnel, margen, export.         | Dashboard, ocupación, funnel, margen por sitio/campaña, reporte visual, testigos por evidencia. | Proof-of-play real bloqueado por CMS; <code>reporte_publicacion_url</code> es mock; export a Excel/PDF no existe. | <div>● Parcial</div> |
| Portal de cliente           | Acceso por token sin login, pipeline sin precios, evidencias, aprobar propuesta. | Portal por token público (sin id enumerable), con seguimiento y aprobación de propuesta.        | —                                                                                                                 | <div>● OK</div>      |

EJE · CONTROL DE ACCESO

# Permisos, roles y autenticación

RBAC real en tabla `rol_permisos` consultada por `exigir(módulo, acción)` en cada endpoint, más un segundo candado (*control de cambios*: contraseña del Dueño) sobre acciones de dinero. Sólido en lo esencial; con huecos de endurecimiento.

| MÓDULO         | DUEÑO                  | COMERCIAL   | OPERACIONES | IMPRENTA    | FINANZAS               |
|----------------|------------------------|-------------|-------------|-------------|------------------------|
| dashboard      | ver                    | ver         | —           | —           | ver                    |
| comercial      | ver · crear · aprobar  | ver · crear | ver         | —           | —                      |
| arrendadores   | ver · crear · aprobar  | —           | —           | —           | —                      |
| operaciones    | ver · crear · aprobar  | —           | ver · crear | ver         | —                      |
| imprensa       | ver · crear · aprobar  | —           | ver         | ver · crear | —                      |
| finanzas       | ver · crear · facturar | —           | —           | —           | ver · crear · facturar |
| network        | ver · crear            | ver         | —           | —           | —                      |
| administracion | ver · crear · aprobar  | —           | —           | —           | —                      |

**ALTA**

**IDOR entre tenants en usuarios.** `PATCH/DELETE /api/usuarios/:id` opera sólo por id, sin filtro de tenant, y la tabla `usuarios` quedó excluida de la RLS fail-closed. Con la conexión superusuario de *dev* es explotable; en prod se mitiga por el rol `spaces_user`. `usuarios-repo.ts:52,76` · `arr_m5_rls_failclosed.sql:11`

**MEDIA**

**RLS parcial.** Solo 7 tablas (inmuebles, sitios, proof-of-play) son fail-closed + FORCE; el resto (clientes, campañas, facturas, usuarios...) siguen fail-open sin FORCE. `arr_m5_rls_failclosed.sql` · `schema.sql:580-599`

**MEDIA**

**Lecturas sin gate por módulo.** `GET` de sitios, OT, impresión y `/estado` sólo exigen sesión: cualquier rol autenticado del tenant puede listarlos aunque el menú se los oculte. `sitios/route.ts:11` · `ot/route.ts:13` · `estado/route.ts:33`

**MEDIA**

**Desbloqueo sin rate-limit.** `/api/cambios/desbloquear` valida la contraseña del Dueño con `bcrypt` pero sin limitar intentos (a diferencia de login/signup): fuerza bruta posible. `cambios/desbloquear/route.ts:14`

**BAJA**

**Perfil sin re-autenticación** (cambia email/contraseña sin pedir la actual), **POST playlogs gateado con ver**, cookie no-`Secure` por defecto y sin token CSRF (solo `sameSite:lax`), y **matriz de la UI desincronizada** de la aplicada. `perfil-controller.ts` · `playlogs/route.ts:29` · `auth.ts:114`

**Lo que está bien:** `bcrypt` cost 10 con política mínima, hash nunca expuesto, desbloqueo del Dueño vive en el servidor con expiración de 15 min, portal y propuesta pública resueltos solo por token aleatorio (cierra el IDOR clásico), signup fuerza rol `DUENO`. En **producción la app conecta como** `spaces_user` (sin superusuario ni bypass de RLS), así que las políticas fail-closed sí se aplican.

**EJE · ARCHIVOS**

## Subida de imágenes y documentos

Existe un módulo de storage a DigitalOcean Spaces (`storage.ts`), S3, objetos privados con URL firmada), pero **solo lo usa la evidencia de OT** y **está inactivo**: ni el `.env.local`

ni el `.env.production` tienen las variables `DO_SPACES_*`. Verificado en prod: **todo se guarda como base64 en la BD.**

| PUNTO DE SUBIDA                        | MECANISMO                              | LÍMITE  | VALIDACIÓN MIME | ESTADO REAL                               |
|----------------------------------------|----------------------------------------|---------|-----------------|-------------------------------------------|
| Adjuntos de pago (factura/comprobante) | base64 → BD                            | 5 MB    | Sí (allowlist)  | Base64 · <b>único con validación real</b> |
| Evidencia de OT (foto)                 | Spaces si activo, si no base64         | Ninguno | Ninguna         | Base64 (Spaces inactivo)                  |
| Logo de la empresa                     | base64 → BD (escritura cruda, sin zod) | Ninguno | Ninguna         | Base64                                    |
| Creatividad (imagen / HTML)            | base64 / texto → BD                    | Ninguno | Ninguna         | Base64                                    |
| Fotos de sitios/pantallas              | base64 → BD (array)                    | Ninguno | Ninguna         | Base64                                    |
| PDF del contrato de arrendamiento      | base64 → BD (string libre)             | Ninguno | Ninguna         | Base64 · no valida que sea PDF            |
| OC de campaña                          | base64 / URL → BD                      | Ninguno | Ninguna         | Base64/URL                                |
| Reporte de publicación (doc)           | —                                      | —       | —               | Mock · el server nunca lo persiste        |

**Riesgos.** (1) **6 de 7 puntos reales no tienen límite de tamaño ni validación de MIME** — un `curl` puede insertar cientos de MB en la BD o subir un binario arbitrario etiquetado como JPEG. (2) La **foto de OT sube a Spaces (cuando está activo) sin validar** y con `ContentType` fijo. (3) El logo entra por **escritura cruda sin zod** y se renderiza como `<img>`. (4) La infraestructura de Spaces existe y hay **script de backfill**, pero requiere activar el bucket + correr la migración `base64→objeto`: hoy no está hecho ni en local ni en prod.

EJE · SISTEMAS

# Brechas transversales para producción

BLOQUEANTE · EXTERNO

## Timbrado fiscal

El folio es un UUID simulado; sin PAC (CFDI MX / SUNAT PE) no hay factura legal. Es el bloqueante #1 para operar de verdad.

FALTANTE · NOTIFICACIONES

## Sin correo ni SMS

Todas las notificaciones son in-app. Grep de resend/nodemailer/twilio en el shell vivo = 0. Las alertas de renta, cobranza y OT no salen del sistema.

FALTANTE · SCHEDULER

### Sin cron / reloj

TTL de reservas, OT vencidas y recordatorios corren **on-request dentro de** `GET /api/estado`. Si nadie abre la app, nada caduca ni se alerta.

PARCIAL · INTEGRACIÓN

### DOOHmain proof-of-play

Se publica de verdad (tras flag), pero las reproducciones se guardan crudas y no se interpretan/cobran: la API real aún responde `[]`. Métricas AdMobilize son stub.

PENDIENTE · STORAGE

### Spaces inactivo

Objeto storage implementado pero sin variables de entorno en prod → todo base64 en BD (infla filas y backups). Falta activar bucket + backfill.

DEUDA · ARQUITECTURA

### Segundo frontend muerto

Los route groups

`(comercial)/(inmuebles)/(operaciones)/admin` apuntan a `apps/api` (Fastify) apagado en prod. Código presente sin backend: confunde, no funciona.

## RECONCILIACIÓN

# Deuda de documentación: brechas ya cerradas

Las auditorías del repo (`ESTADO_COMPLETITUD.md`, `Auditoria_Arrendadores_Rentas.txt`) listan como pendientes varias cosas que **el código ya resolvió**. Verificado en esta auditoría:

#### ● Propuesta → campaña

La aprobación de propuesta genera la campaña y reservas (probado E2E). El "corte" que reportaba la auditoría ya no existe.

#### ● Calendario de rentas

Alta de contrato genera el calendario de pagos (12 periodos verificados). Antes marcado "NO EXISTE".

#### ● Editar/renovar/cancelar contrato

Los tres endpoints existen y funcionan (renovar probado). Antes "ROJO".

#### ● Adjuntos de pago

Factura y comprobante con UI + ruta dedicada y validación 5 MB/MIME. Antes "sin UI".

#### ● Guard OOH → creativo

El server rechaza creativo en campaña fija. Antes pendiente "B1".

#### ● Bitácora inmutable

Migración append-only aplicada. Antes marcada "mutable".

## PLAN

# Priorización recomendada

## ● Cerrable por código

- Filtro de tenant explícito en usuarios + extender RLS FORCE a todas las tablas.
- Rate-limit en el desbloqueo; re-auth para cambio de credenciales.
- Gate `ver` por módulo en los GET; corregir POST playlogs.
- Validación de tamaño + MIME en todos los uploads (no solo pagos).
- Sincronizar la matriz de permisos de la UI con la aplicada.
- Retirar o aislar el segundo frontend muerto.

## ● Operación / decisión

- Activar bucket Spaces + correr backfill base64→objeto.
- Añadir un scheduler real (cron) para TTL, OT y cobranza.
- Proveedor de correo para alertas (renta, cobranza, OT).
- Módulo de liquidación de comisiones a agencias.
- Export a Excel/PDF; PDF real de propuesta.
- Forzar TLS + `COOKIE_SECURE=1` en prod.

## ● Bloqueado por externo

- Timbrado CFDI/SUNAT vía PAC (contrato + certificados).
- Proof-of-play real: contratos/API keys de CMS (Broadsign/Invidis) y AdMobilize.
- DOOHmain: api\_key/contrato para interpretar reproducciones y cerrar idempotencia de reenvío.

**Lectura de conjunto:** el sistema **hace** casi todo el negocio que se le pide y lo hace de verdad contra la base de datos. Para pasar de "demo funcional" a "producción" el trabajo restante es sobre todo de **endurecimiento** (permisos/RLS/uploads), **infraestructura** (storage, scheduler, correo) y **habilitación externa** (timbrado y CMS), no de reconstruir el flujo.